

LEY MARCO DE CIBERSEGURIDAD N°21.663 — REPORTE CSIRT NACIONAL

Formato de Reporte de Incidente al CSIRT Nacional

Proyecto	Cumplimiento Ley Marco de Ciberseguridad N°21.663
Organización	Laboratorio Clínico ACLIN Ltda.
RUT Organización	79.749.170-5
Periodo de cumplimiento	Octubre 2025 – Octubre 2026
ID del Incidente	INC-2025-003
Fecha de emisión del reporte	17 / 10 / 2025

Clasificación: Confidencial — Jaime Gómez Ayala — Auditor
Externo de Ciberseguridad

REPORTE FORMAL AL CSIRT NACIONAL — INC-2025-003 | Incidente CRÍTICO: Vulnerabilidad IDOR + Exposición masiva datos médicos | Enviado 17/10/2025 dentro del plazo legal de 24 h (Art. 23 Ley 21.663)

1. IDENTIFICACIÓN DEL ORGANISMO

Nombre de la entidad	Laboratorio Clínico ACLIN Ltda.
RUT	79.749.170-5
Dirección institucional	9 Norte N°795, Viña del Mar, Región de Valparaíso
CISO / Responsable	Paulina Tapia Hernández · seguridad@aclin.cl · +56 9 7452 7614
Auditor Externo	Jaime Gómez Ayala · RUT 16.302.178-1

2. DETALLE DEL INCIDENTE

Fecha y hora de detección	14/10/2025 – 10:00 hrs.
Sistema / activo afectado	Portal de pacientes: pacientes.aclin.cl (Microsoft IIS 10.0, Windows Server, SQL Server 2019 pto. 1122)
Tipo de incidente	CRÍTICO — Vulnerabilidad IDOR explotada — Exposición masiva de datos médicos y extorsión
Nivel de severidad	 CRÍTICO
Estado al momento del reporte	Contenido — Análisis forense completado por NIVEL4 Forensics (17/10/2025)

3. DESCRIPCIÓN TÉCNICA Y ANÁLISIS PRELIMINAR

Incidente detectado el 14/10/2025 cuando un actor malicioso contactó a representantes de ACLIN exigiendo USD \$1.000 en Bitcoin, afirmando haber obtenido 21.000 exámenes médicos de pacientes. La investigación forense determinó que el origen corresponde a una vulnerabilidad IDOR en el endpoint /resultados/Pacientes/verexámenes.asp?id_cliente= del portal pacientes.aclin.cl.

El parámetro `id_cliente` contenía un identificador numérico codificado en Base64 sin validación de autorización. Un script automatizado pudo iterar los identificadores y descargar exámenes médicos en PDF masivamente. El análisis de logs del servidor (`C:\inetpub\logs\LogFiles\W3SVC4`) confirma 1.115 solicitudes al recurso `/resultados/PACIENTES/PDF/` entre el 25/03/2025 y el 14/10/2025. Las IPs maliciosas 52.34.76.65 y 54.71.187.124 fueron identificadas como actores de amenaza, responsables de 438 solicitudes combinadas.

4. EVALUACIÓN DE IMPACTO

Dimensión CIA	Evaluación
Confidencialidad	COMPROMETIDA — ~21.000 exámenes médicos de pacientes accedidos de forma no autorizada
Integridad	No afectada — El ataque fue exclusivamente de lectura y extracción de datos
Disponibilidad	No afectada — El servicio continuó operativo durante todo el período
Datos personales	EXPUESTOS — Resultados de exámenes clínicos (datos sensibles de salud) de pacientes de ACLIN Ltda.

5. ACCIONES EJECUTADAS

- Análisis forense por NIVEL4 Forensics — acceso remoto al servidor. Informe v1.0 emitido el 17/10/2025.
- Recolección y análisis de logs del servidor IIS 10.0 (`C:\inetpub\logs\LogFiles\W3SVC4`).
- Identificación y confirmación de vulnerabilidad IDOR en endpoint `verexamenes.asp`.
- Bloqueo de IPs maliciosas confirmadas: 52.34.76.65 y 54.71.187.124.
- Corrección de vulnerabilidad IDOR: implementación de validación de autorización por sesión.
- Cierre del puerto MSSQL 1122 expuesto externamente.
- Implementación de HTTPS/TLS 1.3 y headers de seguridad HTTP.
- Implementación de reCAPTCHA en portal de pacientes.

6. MEDIDAS PREVENTIVAS

- Revisión integral de todos los endpoints con parámetros de identificación similares (`id_cliente`, `id_paciente`, etc.).
- Implementación de SIEM y alertas automáticas para detectar comportamiento anómalo en logs.
- Realización de ethical hacking periódico (mínimo anual) en todos los sistemas críticos expuestos a Internet.
- Capacitación de personal TI en seguridad de aplicaciones web (OWASP Top 10).

7. COORDINACIÓN CON CSIRT NACIONAL

El incidente fue clasificado como CRÍTICO por involucrar exposición de datos sensibles de salud. Conforme al Artículo 23 de la Ley Marco de Ciberseguridad N°21.663, el incidente fue notificado al CSIRT Nacional dentro del plazo de 24 horas desde su detección. El presente reporte constituye la notificación formal del incidente INC-2025-003 registrado el 14/10/2025. Responsable del reporte: Paulina Tapia Hernández (CISO), seguridad@aclin.cl.

8. DECLARACIÓN FORMAL

Declaro que la información contenida en este reporte es veraz y corresponde al estado actual del incidente informado, en cumplimiento del Artículo 9 de la Ley Marco de Ciberseguridad N°21.663.

9. FIRMAS

CISO / Responsable de Ciberseguridad

Paulina Tapia Hernández
seguridad@aclin.cl

Firma

Presidenta Comité de Ciberseguridad

M. Ignacia Tapia Baldassare

Firma

Auditor Externo · RUT 16.302.178-1

Jaime Gómez Ayala

Firma

Fecha de aprobación: 17 / 10 / 2025